

ĐẠI HỌC ĐÀ NẴNG
TRƯỜNG ĐẠI HỌC BÁCH KHOA
KHOA CÔNG NGHỆ THÔNG TIN

Tel. (+84.0236) 3736949, Fax. (84-511) 3842771

Website: <http://dut.udn.vn/khoacntt>, E-mail: cntt@dut.udn.vn



BÁO CÁO TUẦN
Thực tập tốt nghiệp - Tuần 1

Họ tên sinh viên	Mã sinh viên
Nguyễn Văn Hoài Nam	102200274
Nguyễn Hoàng Anh	102200009

Đà Nẵng, 11/2024

1. Yêu cầu trong tuần

- Flash WebOS vào thẻ micro-SD để nạp vào Raspberry 4
- Thực hiện triển khai tường lửa cơ bản bằng iptables, netfilter để chống port scanning và DoS/DDoS Attack

2. Báo cáo công việc

a. Flash WebOS vào thẻ micro-SD

[26/11]

Thực hiện theo hướng dẫn trên trang chủ:

<https://www.webosose.org/docs/guides/setup/flashing-webos-ose/>

Không có vấn đề phát sinh

b. Triển khai tường lửa

[26/11]

Nhóm triển khai tường lửa chống port scanning trước. Nghiên cứu công cụ port scanning nmap, nhóm xác định các tools sử dụng cách các flags hoạt động trong TCP Header của các gói tin để xác định cổng mở hay đóng, từ đó thực hiện viết các luật liên quan đến các cờ để chặn port scanning

```
iptables -A INPUT -p tcp --tcp-flags ALL NONE -j DROP
iptables -A INPUT -p tcp --tcp-flags FIN,SYN FIN,SYN -j DROP
iptables -A INPUT -p tcp --tcp-flags SYN,RST SYN,RST -j DROP
iptables -A INPUT -p tcp --tcp-flags FIN,RST FIN,RST -j DROP
iptables -A INPUT -p tcp --tcp-flags FIN,ACK FIN -j DROP
iptables -A INPUT -p tcp --tcp-flags ACK,URG URG -j DROP
iptables -A INPUT -p tcp --tcp-flags ACK,FIN FIN -j DROP
```

Riêng với cờ SYN, do việc gửi gói tin có cờ SYN là một bước trong quá trình TCP Handshake, do đó nhóm thực hiện limit số kết nối từ cùng một địa chỉ IP trong một khoảng thời gian để thực hiện bắt chặn

```
iptables -A INPUT -p tcp --syn -m state --state NEW -m recent --set
iptables -A INPUT -p tcp --syn -m state --state NEW -m recent --update --seconds 60 --hitcount 5 -j DROP
```

Kết quả trước một số loại port scanning
TCP Connect Scan

```

Nmap done: 1 IP address (0 hosts up) scanned in 1.48 seconds

(root@vmkali)-[~]
# nmap -sT 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-26 10:57 EST
Nmap scan report for 10.10.22.236
Host is up (0.19s latency).
All 100 scanned ports on 10.10.22.236 are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 26.67 seconds

```

TCP SYN Scan

```

Nmap done: 1 IP address (1 host up) scanned in 26.67 seconds

(root@vmkali)-[~]
# nmap -sS 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-26 10:58 EST
Nmap scan report for 10.10.22.236
Host is up (0.073s latency).
All 100 scanned ports on 10.10.22.236 are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 15.10 seconds

```

NULL Scan

```

Nmap done: 1 IP address (1 host up) scanned in 15.10 seconds

(root@vmkali)-[~]
# nmap -sN 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-26 10:59 EST
Nmap scan report for 10.10.22.236
Host is up (0.10s latency).
All 100 scanned ports on 10.10.22.236 are in ignored states.
Not shown: 100 open|filtered tcp ports (no-response)
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 17.92 seconds

```

Để thấy các công cụ scan đều trả về kết quả **filtered** - đối với nmap, điều này có nghĩa là không xác định được cổng đang mở hay đóng.

Về chống DDoS, xét 4 kiểu tấn công thử nghiệm để test:

```

# SYN Flood Attack
hping3 -S -p <port> <IP target> --flood
# Random Source Attack

```

```

hping3 -S -p <port> <IP target> --flood -rand-source
# SMURF Attack
hping3 -icmp -flood -spooof <IP target> <IP fake>
# LAND Attack
hping3 -S -p <port> <IP target> -a <IP target>

```

Nhóm nhận thấy 3 trong 4 kiểu tấn công đều sử dụng các request có cờ SYN, còn lại thực hiện tấn công qua ICMP nên nhóm giữ nguyên các luật, đồng thời chặn ICMP

```
iptables -A INPUT -p icmp -j DROP
```

Kết quả

SYN Flood Attack: đã drop được các gói tin

```

selunes@selune: ~
tcp flags:0x06/0x06
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x05/0x05
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x11/0x01
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x30/0x20
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x11/0x01
144K 5773K tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x17/0x02 state NEW recent: SET name: DEFAULT side: source ma
sk: 255.255.255.255
144K 5773K DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
tcp flags:0x17/0x02 state NEW recent: UPDATE seconds: 60 hit_count: 5 n
ame: DEFAULT side: source mask: 255.255.255.255

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination

Chain OUTPUT (policy ACCEPT 134 packets, 14830 bytes)
pkts bytes target prot opt in out source destination

root@raspberrypi4-64:~#

```

Random Source Attack: không ngăn chặn được. Nguyên do là Random Source Attack sử dụng các IP một cách hoàn toàn ngẫu nhiên nên đều sẽ pass qua luật limit cờ SYN.

```
selunes@selune: ~  
root@raspberrypi4-64:~# iptables -L -v -n  
Chain INPUT (policy ACCEPT 161K packets, 6457K bytes)  
pkts bytes target prot opt in out source destination  
46 3312 DROP icmp -- * * 0.0.0.0/0 0.0.0.0/0  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x3F/0x00  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x03/0x03  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x06/0x06  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x05/0x05  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x30/0x20  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
161K 6456K tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x17/0x02 state NEW recent: SET name: DEFAULT side: source ma  
sk: 255.255.255.255  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0
```

SMURF Attack: do đã drop toàn bộ tới ICMP nên drop được hầu hết gói tin

```
selunes@selune: ~  
Chain OUTPUT (policy ACCEPT 3 packets, 336 bytes)  
pkts bytes target prot opt in out source destination  
root@raspberrypi4-64:~# iptables -Z  
root@raspberrypi4-64:~# iptables -L -v -n  
Chain INPUT (policy ACCEPT 11 packets, 1094 bytes)  
pkts bytes target prot opt in out source destination  
116K 3262K DROP icmp -- * * 0.0.0.0/0 0.0.0.0/0  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x3F/0x00  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x03/0x03  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x06/0x06  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x05/0x05  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x30/0x20
```

LAND Attack: không ghi nhận được thông số ???

```
selunes@selune: ~  
root@raspberrypi4-64:~# iptables -L -v -n  
Chain INPUT (policy ACCEPT 8 packets, 894 bytes)  
pkts bytes target prot opt in out source destination  
0 0 DROP icmp -- * * 0.0.0.0/0 0.0.0.0/0  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x3F/0x00  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x03/0x03  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x06/0x06  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x05/0x05  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x30/0x20  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x17/0x02 state NEW recent: SET name: DEFAULT side: source ma  
sk: 255.255.255.255  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x17/0x02 state NEW recent: UPDATE seconds: 60 hit_count: 5 n
```

```
selunes@selune: ~  
0 tcp flags:0x06/0x06  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x05/0x05  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x30/0x20  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x11/0x01  
0 0 tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x17/0x02 state NEW recent: SET name: DEFAULT side: source ma  
sk: 255.255.255.255  
0 0 DROP tcp -- * * 0.0.0.0/0 0.0.0.0/0  
tcp flags:0x17/0x02 state NEW recent: UPDATE seconds: 60 hit_count: 5 n  
ame: DEFAULT side: source mask: 255.255.255.255  
Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)  
pkts bytes target prot opt in out source destination  
Chain OUTPUT (policy ACCEPT 4 packets, 464 bytes)  
pkts bytes target prot opt in out source destination  
root@raspberrypi4-64:~#
```

[28/11]

Nhóm nhận được code từ phía thầy, link: <https://rentry.co/skqiw6i9>

Phân tích rule:

```
iptables -t mangle -A PREROUTING -m conntrack --ctstate  
INVALID -j DROP
```

Rule này drop các gói tin bị conntrack đánh dấu là INVALID (ví dụ: các gói tin sử dụng các kết nối đã bị đóng, một gói tin UDP đến mà không có một kết nối tương ứng, một gói tin TCP đến từ một địa chỉ IP mà không có bất kỳ kết nối nào đang mở, một gói tin TCP mà không có thông tin cần thiết như ACK, SYN, FIN, hoặc RST theo đúng quy trình 3-way handshake trong TCP....)

```
iptables -t mangle -A PREROUTING -p tcp ! --syn -m  
conntrack --ctstate NEW -j DROP
```

Rule này sẽ drop các gói tin TCP thuộc về các kết nối được conntrack đánh dấu là NEW (các kết nối mới) mà không có cờ SYN.

```
iptables -t mangle -A PREROUTING -p tcp -m conntrack --  
ctstate NEW -m tcpmss ! --mss 536:65535 -j DROP
```

Rule này sẽ drop các gói tin TCP thuộc về các kết nối được conntrack đánh dấu là NEW (các kết nối mới) mà kích thước MSS của chúng nằm ngoài phạm vi 536 – 65535 bytes. MSS (Maximum Segment Size) là kích thước tối đa của dữ liệu (payload) có thể được gửi trong một segment TCP, không bao gồm phần header của gói tin. Việc một gói tin có MSS quá nhỏ thường là dấu hiệu của một cuộc tấn công, trong khi đó MSS quá lớn sẽ làm cho các router/thiết bị mạng không xử lý được gói tin đó

```
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
FIN,SYN,RST,PSH,ACK,URG NONE -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
FIN,SYN FIN,SYN -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
SYN,RST SYN,RST -j DROP iptables -t mangle -A PREROUTING  
-p tcp --tcp-flags FIN,RST FIN,RST -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
FIN,ACK FIN -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
ACK,URG URG -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
ACK,FIN FIN -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags  
ACK,PSH PSH -j DROP  
iptables -t mangle -A PREROUTING -p tcp --tcp-flags ALL
```

```

ALL -j DROP
iptables -t mangle -A PREROUTING -p tcp --tcp-flags ALL
NONE -j DROP
iptables -t mangle -A PREROUTING -p tcp --tcp-flags ALL
FIN,PSH,URG -j DROP iptables -t mangle -A PREROUTING -p
tcp --tcp-flags ALL SYN,FIN,PSH,URG -j DROP
iptables -t mangle -A PREROUTING -p tcp --tcp-flags ALL
SYN,RST,ACK,FIN,URG -j DROP

```

Các rule này sẽ drop các kết nối TCP có các cờ được chỉ định trong từng rule. Ví dụ, rule đầu tiên sẽ loại bỏ các kết nối TCP mà không có cờ nào trong 6 cờ được bật.

```

iptables -t mangle -A PREROUTING -s 224.0.0.0/3 -j DROP
iptables -t mangle -A PREROUTING -s 169.254.0.0/16 -j
DROP
iptables -t mangle -A PREROUTING -s 172.16.0.0/12 -j DROP
iptables -t mangle -A PREROUTING -s 192.0.2.0/24 -j DROP
iptables -t mangle -A PREROUTING -s 192.168.0.0/16 -j
DROP
iptables -t mangle -A PREROUTING -s 10.0.0.0/8 -j DROP
iptables -t mangle -A PREROUTING -s 0.0.0.0/8 -j DROP
iptables -t mangle -A PREROUTING -s 240.0.0.0/5 -j DROP
iptables -t mangle -A PREROUTING -s 127.0.0.0/8 ! -i lo -
j DROP

```

Các rule này sẽ drop các kết nối có dải IP được chỉ định trong từng rule.

```

iptables -t mangle -A PREROUTING -p icmp -j DROP

```

Rule này sẽ drop các gói tin ICMP

```

iptables -t mangle -A PREROUTING -f -j DROP

```

Rule này sẽ drop các gói tin bị phân mảnh - thường xảy ra khi một gói tin trở nên quá lớn để gửi 1 lần duy nhất, khiến cho chúng phải bị chia nhỏ ra trong quá trình truyền tải

```

iptables -A INPUT -p tcp -m connlimit --connlimit-above
111 -j REJECT --reject-with tcp-reset

```

Rule này giới hạn số lượng kết nối TCP từ một địa chỉ IP tới hệ thống. Cụ thể, nếu một IP cố gắng thực hiện 111 kết nối đồng thời, hệ thống sẽ từ chối các kết nối mới từ địa chỉ IP đó, đồng thời gửi một gói tin có cờ RST để kết thúc kết nối ngay lập tức

```
iptables -A INPUT -p tcp --tcp-flags RST RST -m limit --  
limit 2/s --limit-burst 2 -j ACCEPT  
iptables -A INPUT -p tcp --tcp-flags RST RST -j DROP
```

Các rule này sẽ thực hiện limit số lượng gói tin có cờ RST tới hệ thống, cụ thể trong code là 2 gói tin/giây. Tất cả các gói tin có cờ RST nếu vượt quá giới hạn này đều sẽ bị drop.

```
iptables -A INPUT -p tcp -m conntrack --ctstate NEW -m  
limit --limit 60/s --limit-burst 20 -j ACCEPT  
iptables -A INPUT -p tcp -m conntrack --ctstate NEW -j  
DROP
```

Các rule này sẽ thực hiện limit số lượng kết nối được conntrack đánh dấu là NEW (kết nối mới), cụ thể trong code là 60 kết nối mỗi giây và 20 kết nối đồng thời. Tất cả các kết nối mới nếu vượt quá giới hạn này đều sẽ bị drop.

```
iptables -A INPUT -p tcp --dport ssh -m conntrack --  
ctstate NEW -m recent --set  
iptables -A INPUT -p tcp --dport ssh -m conntrack --  
ctstate NEW -m recent --update --seconds 60 --hitcount 10  
-j DROP
```

Các rule này sẽ thực hiện limit số lượng kết nối SSH của một IP, cụ thể trong code là 10 kết nối/60s. Nếu vượt quá giới hạn này, các kết nối SSH tiếp theo tới cùng địa chỉ IP sẽ bị drop.

```
iptables -N port-scanning  
iptables -A port-scanning -p tcp --tcp-flags  
SYN,ACK,FIN,RST RST -m limit --limit 1/s --limit-burst 2  
-j RETURN  
iptables -A port-scanning -j DROP
```

Các rule này sẽ tạo một chuỗi chain mới tên port-scanning, và thêm vào chain đó một rule limit số gói tin TCP có cờ RST tới hệ thống, cụ thể là 1 gói tin/giây và 2 gói tin liên tiếp. Các gói tin TCP có cờ RST nếu vượt quá giới hạn này sẽ bị drop.

Sau khi kiểm tra, nhóm thực hiện xóa các rules liên quan đến spoofing IP cụ thể, do lo ngại việc trùng IP với dải IP đang sử dụng

```
iptables -t mangle -A PREROUTING -s 224.0.0.0/3 -j DROP  
iptables -t mangle -A PREROUTING -s 169.254.0.0/16 -j  
DROP  
iptables -t mangle -A PREROUTING -s 172.16.0.0/12 -j DROP
```



```

root@raspberrypi4-64:~# iptables -t mangle -L -v -n
Chain PREROUTING (policy ACCEPT 42 packets, 3997 bytes)
 pkts bytes target      prot opt in      out     source        destination
    0     0 DROP        all  --  *      *       0.0.0.0/0     0.0.0.0/0
    ctstate INVALID
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:!0x17/0x02 ctstate NEW
147K 5874K DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    ctstate NEW tcpmss match !536:65535
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x00
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x03/0x03
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x06/0x06
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x05/0x05
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x11/0x01
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x30/0x20
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x11/0x01

```

SMURF Attack

```

    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x05/0x05
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x11/0x01
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x30/0x20
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x11/0x01
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x18/0x08
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x3F
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x00
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x29
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x2B
    0     0 DROP        tcp  --  *      *       0.0.0.0/0     0.0.0.0/0
    tcp flags:0x3F/0x37
115K 3209K DROP        icmp --  *      *       0.0.0.0/0     0.0.0.0/0
    0     0 DROP        all  -f  *      *       0.0.0.0/0     0.0.0.0/0

```

LAND Attack

```

pkts bytes target      prot opt in      out     source      destination
Chain PREROUTING (policy ACCEPT 6 packets, 589 bytes)
pkts bytes target      prot opt in      out     source      destination
  0      0 DROP        all  --  *      *       0.0.0.0/0    0.0.0.0/0
    ctstate INVALID
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:!0x17/0x02 ctstate NEW
166K 6643K DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    ctstate NEW tcpmss match !536:65535
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x3F/0x00
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x03/0x03
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x06/0x06
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x05/0x05
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x11/0x01
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x30/0x20
  0      0 DROP        tcp  --  *      *       0.0.0.0/0    0.0.0.0/0
    tcp flags:0x02/0x02

```

NULL Scan và FIN Scan

```

(root@vmkali)-[~]
# nmap -sN 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 06:52 EST
Nmap scan report for 10.10.22.236
Host is up (0.19s latency).
All 100 scanned ports on 10.10.22.236 are in ignored states.
Not shown: 100 open|filtered tcp ports (no-response)
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 27.07 seconds

(root@vmkali)-[~]
# nmap -sF 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 06:53 EST
Nmap scan report for 10.10.22.236
Host is up (0.020s latency).
All 100 scanned ports on 10.10.22.236 are in ignored states.
Not shown: 100 open|filtered tcp ports (no-response)
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 9.71 seconds

```

Kết quả cho thấy các rule mới thực hiện chống DDoS và các kỹ thuật port scanning nâng cao khá tốt, tuy nhiên vẫn còn sót các loại port scanning cơ bản: TCP Connect Scan và TCP SYN Scan

```
(root@vmkali)-[~]
# nmap -sT 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 06:50 EST
Nmap scan report for 10.10.22.236
Host is up (1.8s latency).
Not shown: 99 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 10.95 seconds
```

```
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

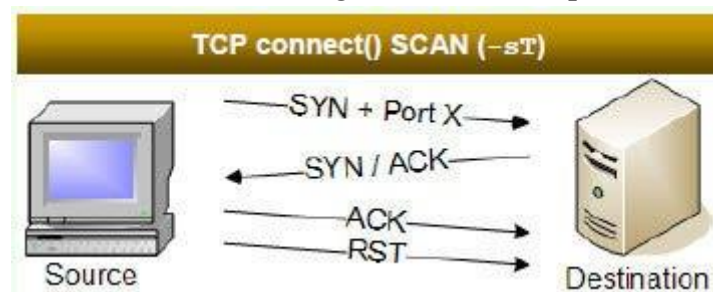
Nmap done: 1 IP address (1 host up) scanned in 10.95 seconds
```

```
(root@vmkali)-[~]
# nmap -sS 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 06:51 EST
Nmap scan report for 10.10.22.236
Host is up (0.019s latency).
Not shown: 99 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 9.42 seconds
```

Xác định nguyên nhân:

TCP Connect Scan và TCP SYN Scan đều dựa trên quá trình TCP Handshake để gửi một gói tin có cờ SYN tới hệ thống nhằm kiểm tra port có mở hay không.



Trong khi đó, list các luật chặn kết nối theo cờ không chứa luật chặn gói tin chỉ có cờ SYN. Đồng thời, chain port-scanning chỉ tập trung vào các gói tin có cờ RST mà bỏ qua các gói tin có cờ SYN.

Khắc phục:

Nhóm thực hiện thêm 2 rule đã áp dụng từ trước đó vào

```
iptables -t mangle -A PREROUTING -p tcp --syn -m state --state NEW -m recent --set
iptables -t mangle -A PREROUTING -p tcp --syn -m state --state NEW -m recent --update --seconds 60 --hitcount 5 -j DROP
```

Kết quả đã chống được các loại port scanning còn sót

```
(root@vmkali)-[~]
# nmap -sT 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 06:57 EST
Nmap scan report for 10.10.22.236
Host is up (0.12s latency).
Not shown: 96 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
1723/tcp  closed pptp
3306/tcp  closed mysql
3389/tcp  closed ms-wbt-server
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 141.73 seconds
```

```
(root@vmkali)-[~]
# nmap -sS 10.10.22.236 -F
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-28 07:10 EST
Nmap scan report for 10.10.22.236
Host is up (0.035s latency).
Not shown: 96 filtered tcp ports (no-response)
PORT      STATE SERVICE
110/tcp   closed pop3
554/tcp   closed rtsp
1720/tcp  closed h323q931
8888/tcp  closed sun-answerbook
MAC Address: D8:3A:DD:A4:BF:C0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 42.38 seconds
```